

Evaluación previa al lanzamiento de una app y de su CEO

Resumen ejecutivo

Con la información actual no es posible emitir una opinión específica sobre **una app concreta, un CEO concreto ni un mercado concreto**, porque faltan tres datos críticos: el nombre de la app, la identidad legal de la empresa y el segmento/industria. Sin esos datos, cualquier juicio sobre competencia, TAM real, cumplimiento regulatorio, reputación del CEO, stack o viabilidad financiera sería especulativo. Lo que sí puede hacerse con rigor es una **diligencia previa al lanzamiento** basada en requisitos verificables de plataformas, marcos de seguridad y textos regulatorios oficiales. ¹

El veredicto provisional, en este estado de información, es **no-go para lanzamiento público abierto y go condicional solo para alfa privada o beta cerrada**, siempre que antes se cumplan cinco puertas de salida: identidad legal verificable, disclosures de privacidad completos, build funcional y testeado, arquitectura/seguridad con controles mínimos, y runway suficiente para sostener soporte, correcciones y adquisición inicial. Esta conclusión no es genérica: Apple exige una versión final, funcional, con metadatos precisos y acceso de revisión si hay login; Google Play exige el formulario de seguridad de datos, una política de privacidad y obligaciones adicionales de verificación/testing en determinados casos. Además, leyes como el RGPD pueden aplicar extraterritorialmente si se ofrecen bienes o servicios a personas en la UE. ²

En términos de decisión, el objetivo del pre-lanzamiento debería ser transformar incertidumbre en evidencia. Si el proyecto no puede responder con documentos, métricas y pruebas a preguntas sobre fundador, producto, seguridad, privacidad, operación y economía unitaria, todavía no está listo para una salida pública. NIST recomienda integrar prácticas de desarrollo seguro a lo largo de todo el ciclo de vida del software, y el CSF 2.0 estructura la gestión del riesgo cibernético como un conjunto de resultados organizacionales, no como una lista cosmética de controles. ³

Dimensión	Estado actual con la información disponible	Veredicto provisional
Identidad empresa/app	No verificable	Bloqueante
CEO y equipo fundador	No verificable	Bloqueante
Producto y propuesta de valor	Solo evaluable como marco	Condicional
Mercado y competencia	Solo por escenarios	Condicional
Seguridad y cumplimiento	Solo contra baseline	Bloqueante si no hay evidencia
Finanzas y runway	Solo por escenarios	Condicional

Dimensión	Estado actual con la información disponible	Veredicto provisional
Decisión actual	Sin insumos críticos	No-go público

Alcance, supuestos e información imprescindible

Este informe asume que la app puede ser **móvil, web o híbrida**, que no existe un mercado geográfico definido de antemano, y que aún no se conocen ni el nombre del CEO ni la jurisdicción de la empresa. Bajo esas condiciones, la mejor práctica no es “inventar” una evaluación específica, sino preparar un **paquete mínimo de evidencia** que permita convertir este marco en una auditoría real en 24-72 horas de trabajo documental.

La siguiente tabla resume los insumos que faltan y cómo obtenerlos de manera trazable:

Insumo crítico	Qué pedir exactamente	Para qué sirve	Cómo obtenerlo
Identidad legal	Nombre legal, país de incorporación, número de registro, dirección oficial	Verificar existencia, titularidad y jurisdicción	Registro mercantil/ estatal, estatutos, documentos de incorporación
Identidad comercial	Nombre de la app, dominio, handles sociales, bundle ID / package name	Confirmar marca, consistencia y posible conflicto IP	Web corporativa, App Store, Google Play, WHOIS, trademark search
CEO y fundadores	Nombre completo, cargo, bio oficial, LinkedIn público, historial laboral, referencias	Evaluar credibilidad, experiencia y fit con el mercado	Web oficial, LinkedIn, notas de prensa, GitHub, conferencias, patentes
Sitio y contratos	Términos, política de privacidad, cookies, DPA, políticas de reembolso	Revisar cumplimiento y modelo contractual	Web oficial y repositorio legal
Producto	Demo, vídeo, credenciales de acceso, screenshots, mapa de flujos, lista de permisos	Validar propuesta de valor y UX real	Demo guiada, build de staging, acceso reviewer
Arquitectura	Diagrama lógico, cloud provider, componentes, SDKs, APIs, CI/CD, secretos	Revisar escalabilidad, seguridad y dependencia de terceros	Arquitectura actual, repos, IaC, SBOM
Seguridad	Threat model, pentest, escaneos SAST/DAST/SCA, política de incidentes	Medir preparación real frente a abuso y vulnerabilidades	Evidencia de herramientas, tickets, reportes, runbooks

Insumo crítico	Qué pedir exactamente	Para qué sirve	Cómo obtenerlo
Mercado	ICP/JTBD, pricing, lista de competidores, entrevistas, retention beta	Evaluar PMF y posicionamiento	Deck, entrevistas, analítica, pruebas beta
Finanzas	Caja, burn, cap table, deuda, runway, hipótesis CAC/LTV	Decidir si el lanzamiento es financiable	Modelo financiero, extractos, invoices, CRM
Go-to-market	Canales, presupuesto, calendario, partnerships, ownership de KPIs	Evaluar si habrá adquisición y soporte suficientes	Plan comercial y calendario de lanzamiento

Como punto de partida documental, los marketplaces ya ofrecen varias señales útiles. En Google Play, la identidad del desarrollador y ciertos datos de contacto deben verificarse y mostrarse al usuario; Apple exige una URL de política de privacidad y disclosures de privacidad de la app en App Store Connect. Eso no sustituye el due diligence corporativo, pero sí sirve como primera capa de verificación pública y consistencia externa. ⁴

Evaluación estratégica de compañía, CEO, producto y mercado

La evaluación del **CEO** debería centrarse en cuatro ejes: **capacidad, integridad, relevancia sectorial y capacidad de ejecución**. La pregunta no es solo si “ha trabajado en startups”, sino si ha demostrado criterio en producto, contratación, disciplina operativa, manejo de stakeholders y coherencia pública. En ausencia de datos, la recomendación es tratar LinkedIn y perfiles públicos como evidencia **secundaria**, y confirmarlos contra biografías oficiales, documentación corporativa, notas de prensa, repositorios técnicos y referencias directas. Si la empresa planea distribuir en Google Play, la verificación del desarrollador añade una señal formal sobre nombre y dirección legal; Apple, por su parte, obliga a disclosures de privacidad y materials de revisión que también sirven para contrastar narrativa y realidad del producto. ⁵

Eje de evaluación del CEO	Evidencia mínima	Señal positiva	Bandera roja
Trayectoria	Historial laboral verificable, roles, proyectos	Experiencia alineada con el problema que la app resuelve	Saltos frecuentes, logros no verificables
Credibilidad técnica/producto	Demo, decisiones de producto, claridad de roadmap	Explica trade-offs, priorización y distribución	Se apoya solo en visión/marketing
Integridad	Consistencia entre discurso legal, comercial y técnico	Reconoce límites, riesgos y supuestos	Promesas no comprobables, métricas ambiguas
Ejecución	Ritmo de releases, hiring, soporte, cadencia operativa	Entrega con disciplina y ownership claro	Roadmap inflado, sin responsables

Eje de evaluación del CEO	Evidencia mínima	Señal positiva	Bandera roja
Relevancia sectorial	Red, partnerships, conocimiento regulatorio	Conoce restricciones del sector	Desconoce cumplimiento clave
Gobernanza	IP assignments, estructura societaria, board/advisors	Propiedad intelectual y contratos claros	Contratistas sin cesión IP, advisor-washing

En producto, la pregunta central es si la app resuelve una tarea crítica mejor que la alternativa disponible hoy. Apple deja claro que la app no debe ser un simple “repackaged website” y que el metadata, capturas y descripción deben reflejar con precisión la experiencia principal; Google Play exige declarar qué datos se recogen o comparten, incluyendo lo que recogen SDKs de terceros, y revisar permisos/APIs usados por la app. Eso implica que la evaluación de producto no puede separarse de la evaluación de permisos, SDKs, flows de onboarding y datos personales. ⁶

Matriz de funcionalidades	Interno	Beta cerrada	Lanzamiento público	Diferenciación esperada
Onboarding y primera acción valiosa	Obligatorio	Obligatorio	Obligatorio	Debe ser más rápido que la alternativa
Autenticación y recuperación de cuenta	Obligatorio	Obligatorio	Obligatorio	Fricción mínima y seguridad fuerte
Caso de uso principal resuelto de punta a punta	Obligatorio	Obligatorio	Obligatorio	Debe funcionar sin soporte manual
Gestión de permisos/ consentimiento	Obligatorio	Obligatorio	Obligatorio	Transparente y granular
Centro de privacidad y borrado/exportación	Deseable	Obligatorio	Obligatorio	Reduce fricción regulatoria
Analytics y eventos de producto	Obligatorio	Obligatorio	Obligatorio	Permite medir time-to-value
Facturación/pagos	Según modelo	Según modelo	Obligatorio si monetiza	Sin romper UX ni compliance
Soporte in-app / ayuda / FAQs	Deseable	Obligatorio	Obligatorio	Reduce churn y tickets
Consola admin / backoffice	Deseable	Deseable	Obligatorio si hay operaciones manuales	Aumenta eficiencia operativa

Matriz de funcionalidades	Interno	Beta cerrada	Lanzamiento público	Diferenciación esperada
APIs/webhooks/exportación	No siempre	Deseable	Obligatorio si el caso de uso es B2B/ plataforma	Moat e integración
Modo offline / tolerancia a mala conectividad	Según categoría	Deseable	Muy recomendable en móvil	Mejora UX real

Sin geografía definida, no conviene presentar un TAM “global” como si fuera el mercado real. A lo sumo, puede usarse el mercado digital conectado como techo superior: el Banco Mundial, con datos de la UIT, sitúa el uso de Internet mundial en **74% de la población en 2025** y las suscripciones móviles en **112 por cada 100 personas en 2025**. Ese dato no es TAM; es solo el límite exterior antes de filtrar por segmento, problema, capacidad de pago, idioma, regulación y canal. ⁷

Modelo	Fórmula de TAM	Escenario ilustrativo de TAM	Escenario ilustrativo de SAM	Escenario ilustrativo de SOM
B2C suscripción	Usuarios relevantes × gasto anual esperado	2,000,000 usuarios × US\$60/año = US\$120M	500,000 usuarios en geos/canales iniciales = US\$30M	25,000 pagadores = US\$1.5M ARR
B2B SaaS	Cuentas objetivo × ACV	100,000 cuentas × US\$1,800 = US\$180M	20,000 cuentas accesibles = US\$36M	800 logos = US\$1.44M ARR
Marketplace	GMV anual de la categoría × take rate	US\$500M GMV × 10% = US\$50M	US\$100M GMV = US\$10M	US\$8M GMV = US\$0.8M

Los valores de la tabla anterior son supuestos ilustrativos para modelado, no estimaciones del mercado real de una empresa específica.

La tabla competitiva debería construirse siempre desde **fuentes primarias**: website del rival, pricing page, docs, trust/security page, status page, ToS/privacy, y listings oficiales en App Store/Google Play. Sin nombre de app ni sector, la mejor comparación posible por ahora es por **tipo de competidor**:

Tipo de competidor	Qué suele hacer mejor	Qué suele hacer peor	Evidencia primaria a revisar	Respuesta de posicionamiento
Directo puro	Resuelve el mismo JTBD	Menor flexibilidad o menor foco	Pricing, onboarding, reviews, roadmap público	Diferenciar en foco, UX o economics

Tipo de competidor	Qué suele hacer mejor	Qué suele hacer peor	Evidencia primaria a revisar	Respuesta de posicionamiento
Incumbente	Marca, distribución, confianza	Lentitud, complejidad, precio	Web, contratos, SLAs, casos de uso	Ganar por simplicidad/ velocidad
Sustituto manual	Coste bajo inicial	Mala escalabilidad y trazabilidad	Procesos actuales del cliente	Cuantificar tiempo/ errores ahorrados
Plataforma amplia	Integraciones y ecosistema	Producto menos vertical	Docs, APIs, marketplace	Ganar por profundidad vertical
AI wrapper / nueva startup	Velocidad y novedad	Menor defensa y mayor churn	Demo, pricing, claims, seguridad	Ganar por confiabilidad y ejecución

En economía unitaria, la disciplina depende del modelo. Para SaaS B2B, Bessemer sugiere como referencia que el **CAC payback** sea inferior a **12 meses** para cuentas SMB, inferior a **18 meses** para mid-market y menor de **24 meses** para enterprise; además, usa como regla práctica un **CLTV/CAC $\geq 3x$** . ChartMogul muestra también que el churn tiende a caer a medida que sube el ARPA: en su benchmark, la mediana de gross MRR churn mensual baja de **8.2%** en ARPA $\leq$ US\$25 a **2.4%** en ARPA $>$ US\$500. En consumo por suscripción, RevenueCat observa que los planes **anuales** retienen y renuevan muy por encima de planes mensuales o semanales, lo que vuelve razonable testear pricing anual desde etapas tempranas si la propuesta de valor soporta compromiso. ⁸

Evaluación técnica, seguridad y operaciones

La arquitectura mínima aceptable antes del lanzamiento debería permitir separar claramente **cliente, autenticación, API, lógica de negocio, datos, observabilidad y controles administrativos**. NIST SSDF recomienda integrar prácticas de desarrollo seguro en el SDLC para reducir vulnerabilidades, mitigar impactos y atacar causas raíz; el NIST CSF 2.0 ofrece una taxonomía de resultados para gobernar esos riesgos a nivel organizacional. En práctica, eso significa entornos separados, gestión formal de secretos, branch protection, revisión de código, escaneo de dependencias, pipeline reproducible, backups restaurables y ownership claro por servicio. ⁹

En la decisión **móvil nativo vs web vs híbrido**, el criterio no debería ser “qué es más rápido de construir”, sino qué experiencia exige el caso de uso. Si la app necesita integrarse profundamente con cámara, sensores, notificaciones, background tasks, offline fuerte o biometría, el móvil nativo gana peso. Si lo decisivo es iterar rápido, SEO, distribución web o workflows B2B, una base web o un backend API-first puede ser superior. La evaluación del stack debe revisar también dependencia de SDKs y APIs externas, porque Apple exige disclosures de privacidad que incluyen partners/SDKs y Google Play obliga a revisar también qué datos recogen o comparten esos terceros. ¹⁰

Para seguridad, recomiendo modelar amenazas con **STRIDE** y, después, mapearlas contra **OWASP Top 10 2021** y **OWASP API Security Top 10 2023**. OWASP identifica entre los riesgos web más críticos el control de acceso roto, fallos criptográficos, inyección, diseño inseguro y fallos de logging/monitorización; para APIs,

destaca autorización rota a nivel de objeto o función, consumo no restringido de recursos, misconfiguración de seguridad, mala gestión de inventario y consumo inseguro de APIs. Esa combinación obliga a revisar especialmente authN/authZ, rate limiting, tenancy boundaries, exposición de objetos, inventario de endpoints y seguridad de integraciones. Microsoft describe STRIDE como un marco para categorizar amenazas por suplantación, manipulación, repudio, divulgación de información, denegación de servicio y escalación de privilegios. ¹¹

Superficie	Riesgos más probables	Controles mínimos recomendados
Cliente móvil/web	Reverse engineering, robo de sesión, abuso del flujo	Almacenamiento seguro, protección de sesión, certificados, feature flags, detección de abuso
API	BOLA/BFLA, abuso de recursos, enumeración, SSRF	OAuth/JWT bien implementado, autorización por objeto, rate limits, schema validation, inventory de endpoints
Datos	Exfiltración, acceso interno indebido, borrado inadecuado	Cifrado en tránsito y reposo, RBAC, rotación de claves, auditoría, retención/borrado
CI/CD	Supply chain, secretos filtrados, releases inseguros	Firma, escaneo SCA/SAST, secretos en vault, aprobación de despliegues, rollback
Terceros/ SDKs	Recolección no declarada, crash/fuga de datos	Inventario, privacy manifest, revisión contractual, minimización de SDKs
Admin/backoffice	Escalación, fraude interno, errores operativos	MFA, mínimos privilegios, segregación de funciones, auditoría y alertas

En plataformas móviles hay controles adicionales de alto valor. En Android, Google Play ofrece **Play Integrity API, automatic protection, Play app signing** y otros servicios de integridad para detectar binarios modificados, instalaciones no genuinas o dispositivos no confiables. En Apple, **App Attest** permite demostrar al servidor que ciertas solicitudes vienen de instancias legítimas de la app, y Apple también está reforzando la cadena de suministro con **privacy manifests** y firmas de SDKs de terceros. Estos controles no sustituyen la seguridad del backend, pero sí elevan el coste del abuso y mejoran la confianza en acciones sensibles. ¹²

En operaciones, la app debería salir con observabilidad suficiente para ver lo mismo que ve el usuario: **métricas, logs y trazas**. Google SRE resume las cuatro señales doradas como **latencia, tráfico, errores y saturación**, y su guía de observabilidad insiste en usar métricas, logs y trazas como base para detectar fallos potenciales y definir SLIs/SLOs. A nivel de infraestructura, los patrones de balanceo con health checks y autoscaling ayudan a absorber picos de tráfico y aislar instancias no sanas. Si el proyecto no tiene SLOs, runbooks, dashboards y un responsable de incidentes, no está listo para pasar de beta controlada a lanzamiento abierto. ¹³

Evaluación legal, regulatoria y financiera

En privacidad y compliance, el punto más importante es aceptar que **la jurisdicción no depende solo de dónde está la empresa**, sino también de **dónde están los usuarios, qué datos se tratan y qué sector opera la app**. El RGPD se aplica al tratamiento realizado en el contexto de un establecimiento en la UE y

también, aunque el responsable no esté establecido en la UE, cuando ofrece bienes o servicios a personas en la Unión o monitoriza su comportamiento; además, sus principios incluyen licitud, transparencia, limitación de finalidad, minimización, integridad/confidencialidad y accountability. La LGPD brasileña contiene un alcance igualmente amplio cuando la operación se realiza en Brasil o busca ofrecer bienes/servicios o tratar datos de personas localizadas allí. En el Reino Unido, UK GDPR y PECR obligan a pensar no solo en bases legales y minimización, sino también en comunicaciones electrónicas y marketing. En California, la CCPA implementa y hace cumplir la CCPA/CPRA. ¹⁴

Región o tema	Cuándo aplica	Requisito mínimo antes de lanzar	Base oficial
Unión Europea	Usuarios o tratamiento relacionado con personas en la UE	Base legal, notice, minimización, derechos del interesado, transferencias y seguridad	RGPD, arts. 3 y 5 ¹⁵
Reino Unido	Usuarios/operaciones en UK	UK GDPR + PECR para marketing/comunicaciones	ICO UK GDPR/PECR ¹⁶
California	Si entras en el ámbito CCPA/CPRA por umbrales/actividad	Notice, derechos del consumidor, contratos y gobernanza de datos	CCPA ¹⁷
Brasil	Tratamiento en Brasil o oferta a personas allí	Consentimiento/base legal, notice, derechos, seguridad y transferencias	LGPD ¹⁸
Niños	Servicio dirigido a menores de 13 en EE. UU. o conocimiento de esa recolección	Notice a padres, consentimiento verificable, límites de retención y seguridad	FTC COPPA ¹⁹
Salud	Si manejas ePHI/PHI en EE. UU. y eres covered entity/BA	Salvaguardas administrativas, físicas y técnicas; privacidad y breach handling	HHS HIPAA ²⁰
Pagos	Si procesas datos de tarjetas	Alcance PCI DSS, segmentación, MFA, hardening y validación	PCI DSS v4.x ²¹
IA	Si la app usa IA con obligaciones regulatorias, especialmente en la UE	Clasificar riesgo, transparencia, gobernanza y documentación	Reglamento UE de IA ²²

A nivel de propiedad intelectual, antes de lanzar debería estar cerrado, como mínimo, lo siguiente: **cesión de IP** de fundadores, empleados y contractors; inventario y licencias de open source; búsqueda de marca; política de uso de datasets/modelos; y contratos con terceros que determinen roles de controlador/encargado o proveedor/processor según aplique. Si esto falta, el lanzamiento puede suceder, pero la empresa sigue jurídicamente frágil.

En finanzas, al no existir datos reales de caja, cap table, salarios, nube y CAC, la aproximación correcta es trabajar por **escenarios**. La fórmula base es simple: **runway = caja / burn neto mensual**. Para un lanzamiento, lo peligroso no es solo “quedarse sin dinero”, sino lanzar con caja insuficiente para soportar los primeros 90-180 días de incidencias, devoluciones, adquisición, soporte y cambios de roadmap.

Arquetipo	Qué necesitas para ~US\$1M ARR anualizado	Burn mensual ilustrativo	Caja para 12 meses
B2C suscripción a US\$8/mes	~10,417 suscriptores de pago	US\$60k–180k	US\$720k–2.16M
B2B SaaS a ACV de US\$2,400	~417 clientes	US\$80k–250k	US\$960k–3.0M
Marketplace a take rate de 10%	~US\$10M GMV anual	US\$100k–300k	US\$1.2M–3.6M

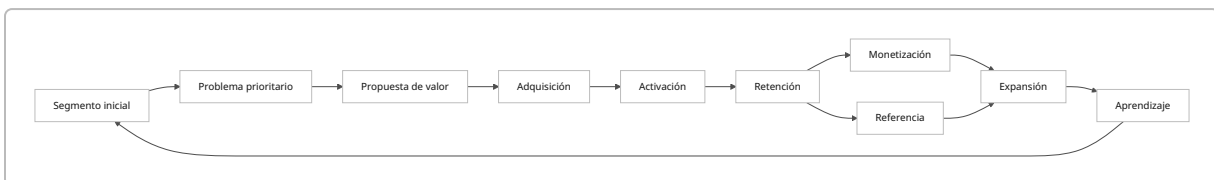
Escenarios ilustrativos propios para modelado, no benchmarks de mercado.

Como referencia operativa, un caso B2B SMB con precio de US\$200 MRR, margen bruto del 80% y CAC de US\$1,500 tendría un CAC payback aproximado de **9.4 meses**; si el churn es moderado, estaría mejor alineado con los rangos de eficiencia sugeridos por Bessemer para SMB que muchos proyectos con pricing demasiado bajo y churn alto. En B2C, por el contrario, el gran riesgo es lanzar una suscripción con pricing/plazo equivocados: RevenueCat muestra que los planes semanales suelen destruir retención comparados con los anuales. ²³

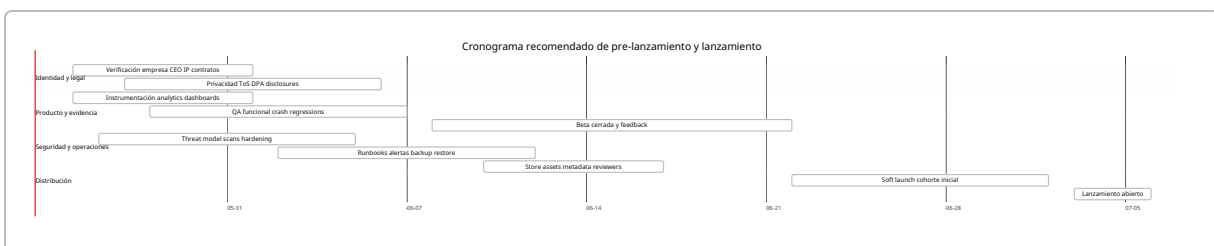
Recomendaciones, métricas, OKRs y checklist de lanzamiento

La recomendación principal es convertir el proyecto en un proceso de **gates**. Sin nombre de app, CEO o sector, la decisión correcta no es “lanzar o no lanzar ahora”, sino fijar una secuencia: **alfa interna → beta cerrada → lanzamiento limitado por cohorte/geografía → lanzamiento abierto**. Apple recomienda usar **TestFlight** para betas, no el App Store, y Google Play recomienda empezar por testing interno y luego cerrado; además, para nuevas cuentas personales creadas después del 13 de noviembre de 2023, Google exige una prueba cerrada con al menos **12 testers** opt-in durante **14 días continuos** antes de poder solicitar acceso a producción. ²⁴

El flujo ideal de product-market fit y aprendizaje debería verse así:



Y un cronograma de lanzamiento razonable, partiendo del 23 de mayo de 2026, sería el siguiente:



El dashboard ejecutivo debería combinar negocio, producto, fiabilidad y seguridad en una sola vista. Google SRE insiste en medir latencia, tráfico, errores y saturación, y la observabilidad moderna añade también negocio y operaciones de soporte. ²⁵

Área	KPI sugerido	Fórmula o definición	Dueño
Adquisición	CAC por canal	Gasto por canal / clientes adquiridos	Growth
Adquisición	CVR store/landing	installs o signups / visitas	Growth
Activación	Activación de usuario	% que alcanza primer valor	Product
Activación	Time-to-value	tiempo hasta completar la acción principal	Product
Retención	D1/D7/D30 o WAU/MAU	cohortes o stickiness	Product
Monetización	Conversión a pago	pagadores / usuarios activados	Growth/Finance
Monetización	ARPU/ARPPU/MRR/ARR	estándar por modelo	Finance
Soporte	Tickets por 1,000 usuarios y FRT	volumen y tiempo de primera respuesta	Ops/Support
Fiabilidad	Availability / crash-free sessions	uptime y sesiones sin crash	Engineering
Fiabilidad	p95/p99 latency y error rate	SLIs por servicio	SRE/Engineering
Seguridad	Vulnerabilidades críticas abiertas	conteo y edad	Security
Seguridad	MTTR y parches de dependencias	tiempo medio de remediación	Security/Engineering
Privacidad	SLA DSAR y borrados	tiempo de atención de solicitudes	Legal/Ops
Finanzas	Burn neto, runway, burn multiple	caja y net new ARR	Finance

Un conjunto inicial de OKRs puede ser el siguiente:

Objetivo	Key Results sugeridos
Demostrar ajuste producto-segmento inicial	KR1: activación del segmento inicial por encima del objetivo interno definido; KR2: D30/retención del cohort beta suficiente para repetir adquisición; KR3: NPS o satisfacción de soporte superior al baseline definido
Lanzar sin incidentes severos	KR1: 0 vulnerabilidades críticas abiertas al momento del launch; KR2: crash-free sessions > 99.5%; KR3: disponibilidad y latencia dentro del SLO acordado

Objetivo	Key Results sugeridos
Validar economía unitaria defendible	KR1: CAC medido por canal; KR2: payback dentro del rango objetivo del modelo; KR3: LTV/CAC compatible con crecimiento sostenible
Crear confianza legal y operativa	KR1: política de privacidad, términos y disclosures aprobados; KR2: proceso DSAR y borrado probado; KR3: runbooks y owner de incidentes asignados

La matriz de riesgos y mitigaciones que más probablemente determine el éxito o fracaso del lanzamiento es la siguiente:

Riesgo	Señal temprana	Impacto	Mitigación
CEO/equipo sin fit real	Narrativa fuerte pero evidencia débil	Mala ejecución y fundraising difícil	Verificación biográfica y referencias
PMF insuficiente	Activación/retención flojas en beta	CAC improductivo y churn alto	Soft launch y aprendizaje por cohortes
Rechazo en stores	Metadata/información incompleta o app inmadura	Retraso y coste reputacional	Checklist de políticas Apple/Google
Incidente de privacidad	SDKs no declarados, notices ambiguos	Riesgo regulatorio y reputacional	Inventario de datos y revisión legal
Vulnerabilidad crítica	AuthZ débil, logs pobres, dependencia vulnerable	Brecha o fraude	Threat modeling + secure SDLC
Caída operativa	No hay SLO, alertas o rollback	Mala experiencia inicial	Observabilidad y on-call mínimo
Falta de runway	Burn alto sin conversión probada	Parálisis post-launch	Lanzamiento secuencial y control de gasto
Dependencia excesiva de terceros	SDK o API externalizada sin plan B	Fallas o costes no previstos	Inventario, contratos y estrategia de contingencia

La checklist final de lanzamiento debería autorizar el paso a producción solo cuando todos los ítems siguientes estén cerrados con evidencia:

Checklist de lanzamiento	Evidencia requerida	Estado
Empresa legalmente identificada y registrable	doc. societarios, titularidad dominio, marca	☐
CEO y equipo verificados	bios, perfiles públicos, referencias, cesión IP	☐
Política de privacidad publicada	URL pública y actualizada	☐

Checklist de lanzamiento	Evidencia requerida	Estado
Términos y mecanismo de soporte publicados	URL pública, email y flujo de soporte	☐
Inventario de datos completo	mapa de datos, SDKs, permisos, bases legales	☐
Disclosures Apple completados	App Privacy / privacy policy URL	☐
Disclosures Google Play completados	Data Safety + privacy policy	☐
Verificación de desarrollador completada	datos legales/contacto correctos en store	☐
Build estable y testeado	QA, crash tests, regresión, smoke tests	☐
Acceso reviewer listo	demo account o demo mode si aplica	☐
Instrumentación analítica activa	eventos, funnels, cohortes	☐
SLOs y alertas activas	dashboard, p95, error rate, uptime	☐
Backups y restore probados	evidencia de restauración	☐
Gestión de secretos y accesos	MFA, RBAC, vault, offboarding	☐
Scans de seguridad ejecutados	SAST/DAST/SCA, dependencias, findings cerrados	☐
Threat model aprobado	STRIDE + API/web/mobile review	☐
Pagos y reembolsos validados	sandbox + producción limitada	☐
Soft launch definido	cohorte, canal, presupuesto, owner	☐
KPI owners asignados	growth, product, eng, legal, ops	☐
Runway suficiente post-launch	caja para operar y corregir	☐

La recomendación final, por tanto, es **condicionar el lanzamiento a evidencia y no a entusiasmo**. Si la empresa puede completar este paquete y demostrar una beta cerrada con activación, retención, seguridad y compliance defendibles, el proyecto pasa a **go limitado**. Si no puede, el riesgo no está en “salir tarde”, sino en salir sin capacidad de aprender, corregir y sobrevivir.

1 2 6 24 App Review Guidelines - Apple Developer

https://developer.apple.com/app-store/review/guidelines/?utm_source=chatgpt.com

3 9 SP 800-218, Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities | CSRC

https://csrc.nist.gov/publications/detail/sp/800-218/final?utm_source=chatgpt.com

4 5 Verify your developer identity information - Play Console Help

https://support.google.com/googleplay/android-developer/answer/10841920?hl=en&utm_source=chatgpt.com

7 Individuals using the Internet (% of population) | Data

https://data.worldbank.org/indicator/IT.NET.USER.ZS?utm_source=chatgpt.com

8 23 Scaling to \$100 Million - Bessemer Venture Partners

https://www.bvp.com/atlas/scaling-to-100-million?utm_source=chatgpt.com

10 App Privacy Details - App Store - Apple Developer

https://developer.apple.com/app-store/app-privacy-details/?utm_source=chatgpt.com

11 OWASP Top 10:2021

https://owasp.org/Top10/2021/?utm_source=chatgpt.com

12 Use the Play Integrity API to detect risky interactions and fight abuse - Play Console Help

https://support.google.com/googleplay/android-developer/answer/11395166?hl=en-EN&utm_source=chatgpt.com

13 25 Google SRE monitoring distributed system - sre golden signals

https://sre.google/sre-book/monitoring-distributed-systems/?hl=fr_fr&utm_source=chatgpt.com

14 15 Reglamento - 2016/679 - EN - GDPR - EUR-Lex

https://eur-lex.europa.eu/legal-content/ES/ALL/?tid=1234&uri=celex%3A32016R0679&utm_source=chatgpt.com

16 A guide to the data protection principles | ICO

https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/data-protection-principles/a-guide-to-the-data-protection-principles/?q=article+4%E2%80%AF%E2%80%AF%C2%A0&utm_source=chatgpt.com

17 About Us - California Privacy Protection Agency (CPPA)

https://cppa.ca.gov/about_us?utm_source=chatgpt.com

18 L13709

https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709.htm?utm_source=chatgpt.com

19 Complying with COPPA: Frequently Asked Questions | Federal Trade Commission

https://www.ftc.gov/business-guidance/resources/complying-coppa-frequently-asked-questions?utm_source=chatgpt.com

20 Summary of the HIPAA Security Rule | HHS.gov

https://www.hhs.gov/hipaa/for-professionals/security/laws-regulations/index.html?form=MG0AV3&utm_source=chatgpt.com

21 Securing the Future of Payments: PCI SSC Publishes PCI Data Security Standard v4.0 - PCI Security Standards Council

https://www.pcisecuritystandards.org/about_us/press_releases/securing-the-future-of-payments-pci-ssc-publishes-pci-data-security-standard-v4-0/?utm_source=chatgpt.com

22 Reglamento (UE) 2024/1689 del Parlamento Europeo y del Conse...

https://eur-lex.europa.eu/legal-content/Es/LSU/?uri=CELEX%3A32024R1689&utm_source=chatgpt.com